



THE PLAN

Legal, data and safety

A checklist of what you must set up, what the law expects of health data, and the one line you must never cross.

Status labels apply throughout: KNOWN, VERIFIED, ASSUMPTION, ESTIMATE, TO VALIDATE, PROPOSED. Nothing in this document claims traction, approvals, partners or revenue that do not exist. Governing file: FACTS_BASE.

PREPARED FOR

The Founder, Vytalix

DATE

8 September 2026

VERSION

1.0 · Confidential draft

Contents

In one minute
What to do
Setting the company up
Rules about health data
When software becomes a medical device
What the NHS asks for before it buys
Owning what you own
Nigeria and other countries
The risk list
Who you must pay for proper advice
Words explained

A checklist of what you must set up, what the law expects of health data, and the one line you must never cross.

This is not legal advice. It is a map so you know what to ask for. Every item marked [SOLICITOR], [ACCOUNTANT], [REGULATORY] or [SAFETY OFFICER] needs a qualified professional before you act on it. Costs are ESTIMATE (our best guess, not a fact) unless a source is named.

In one minute

- You have no company, no insurance, no data registration and no trademark yet (VERIFIED). Nothing can be sold or banked until that changes.
- Health data is the most protected kind of data in UK law. Design your consulting work so it never touches any.
- The moment software predicts, diagnoses or advises on treatment for one person, it becomes a medical device. That is a different company, taking years and a lot of money.
- MaternaLink (in development) is written to stay on the safe side of that line. It only stays there if you check every feature.
- The NHS will not buy anything until you can show four things: DTAC, the data security toolkit, Cyber Essentials and a named clinical safety officer.

What to do

Action	Who	By when
Search the trademark registers; brief a trademark attorney; send draft heads of terms to your collaborator	You + attorney	Fri 18 Sept 2026
Instruct one fixed-fee solicitor and one accountant	You	Fri 18 Sept 2026
Register the company; open the bank account	You + accountant	Fri 25 Sept 2026
Register with the ICO (£52); buy professional indemnity and public liability insurance	You	Fri 2 Oct 2026
Sign the ownership agreement for MaternaLink; finish the prototype check	You + solicitor	Tue 13 Oct 2026

Setting the company up

Task	What it is in plain words	Roughly what it costs	Who does it	When
Companies House registration	Creating the legal company, online. You cannot invoice, bank, insure or take investment without it.	£100 to register; £50 a year after	You; accountant advises on shares	By Fri 25 Sept 2026

Task	What it is in plain words	Roughly what it costs	Who does it	When
Name clearance first	Checking nobody already owns a name close to yours. Two "VITALIX LTD" companies exist and two US firms use near-identical names (VERIFIED).	£500–£1,500 for a written opinion	Trademark attorney	Before any money is spent on the brand
ICO registration	Telling the UK data regulator you hold people's data. Legally required once you run a CRM or a newsletter.	£52 a year (Tier 1)	You	Within 21 days of holding any data
Insurance	Professional indemnity covers advice that goes wrong. Public liability covers accidents. Cyber covers a data breach.	£400–£900 PI; £100–£250 PL; £500–£1,500 cyber	Insurance broker	PI and PL before your first paid job
Accountant	Files your accounts and tax, sets up payroll later, and handles the SEIS and EIS tax paperwork investors expect.	£80–£200 a month	Accountant	On the day you register
Bank account	A company account, fully separate from your own money and from Kemek.	£0–£10 a month	You	Straight after registration
Founder IP assignment	A short signed paper moving your own work into the company. Investors will ask for it.	Part of the solicitor's starter pack	Solicitor	At registration

Selling before the company exists means you sign personally and carry the risk personally. Keep any such contract short, insured, and written so it moves to the company later. Ask your solicitor for the wording.

Rules about health data

UK GDPR in plain words. It is the law about holding information on people. You need a clear reason to hold it. You must tell them, keep it safe, and keep it no longer than you need. They can ask to see it or delete it. Health information gets extra protection on top. So do religion, sex life, ethnicity and biometrics.

Voice recordings are health data too when the person is talking about their health or their pregnancy. A recording also identifies the speaker. Treat every recording as the most sensitive thing you hold.

A DPIA (Data Protection Impact Assessment) is a written exercise. You set out what data you will hold, what could go wrong, and what you will do about it. You must do one before you handle health data at any scale. You also need one for new technology, and where the people involved are vulnerable. MaternaLink meets all three tests, so a DPIA is not optional. Start it before the design is frozen and redo it before each new deployment.

Consulting work should hold no patient data at all. Say so in writing in every contract. If a client insists on sharing personal data, stop and put a data processing agreement in place first.

UK to Nigeria. The UK has made no adequacy decision for Nigeria, which means data cannot simply flow there. You need a written transfer agreement and a risk assessment, or you host the data inside Nigeria so it never leaves. [SOLICITOR] before any Nigerian deployment.

If something goes wrong you have 72 hours to tell the ICO about a reportable breach. Write the procedure now, while nothing is on fire.

When software becomes a medical device

This is the most important page in this document. Read it twice.

The rule. UK law decides what a medical device is by what the maker says the software is for. Does your software do anything about one named person's health? Predict a problem, spot a condition, score a risk, decide who is urgent, suggest a treatment? Then it is a medical device. It does not matter that it is "just an app". It does not matter that a clinician sees the output afterwards.

What that costs. A device maker needs a quality management system, a technical file and clinical evidence. You must monitor the product after launch. Above the lowest class, an approved body has to assess you. The regulatory work alone is £40k–£150k and 9 to 18 months (ESTIMATE). Getting a real product through evidence, staff and the quality system takes two to three years and well over £1m (ESTIMATE). That is a different company from the one you are building now.

Exactly where the line is. MaternaLink version 1 ships nothing that does any of these:

On the safe side	Over the line — needs the full device route
Passing a reading to a midwife exactly as it was entered	Comparing a reading to a threshold and flagging it
Sending a reminder about an appointment	Deciding who should be seen first
Giving general information that applies to every pregnant woman	Giving advice tailored to one woman's readings
Recording what a woman says and showing it to her team	Scoring a questionnaire for a clinical purpose
Keeping notes, messages and records in one place	Producing a risk score, a prediction or an alert

The safe wording, to use everywhere without changing it:

"MaternaLink (in development) is care-coordination software. It helps a maternity team and a woman stay in contact, share information and keep records in one place. It does not diagnose, monitor, predict or advise on treatment. Every clinical decision stays with the woman's own clinician."

How you hold the line. Write the intended-use statement down and make it a company rule. Check every single feature against it before it ships. Anything that fails the check goes on a list for a later decision, not into version 1. A regulatory consultant should confirm your position in writing, ESTIMATE £1,500–£4,000. Buy that opinion; do not decide this one alone. [REGULATORY]

What the NHS asks for before it buys

What they ask for	What it is, in one sentence
DTAC	The NHS checklist a digital product must pass before a hospital can buy it, covering clinical safety, data protection, security, usability and interoperability.
DSPT (Data Security and Protection Toolkit)	An annual self-assessment you submit to show you handle NHS patient data properly; you need "Standards Met".
Cyber Essentials	A government-backed security certificate showing your basics are right: it costs about £300 plus VAT at the smallest tier and takes weeks, not months.
Clinical safety (DCB0129)	The standard that makes you, as the maker, manage clinical risk; you must appoint a Clinical Safety Officer, who must be a registered clinician with the right training.

What they ask for	What it is, in one sentence
Hazard log	The written list of everything that could harm a patient if the software behaved badly, what you did about each one, and who signed it off.

None of these is a one-off. All of them are renewed or re-submitted. Start them early because buyers ask before they talk about price.

Owning what you own

Thing	Where you stand today	What to do
The company name and trademark	Names very close to yours already exist (VERIFIED). This is a real risk of having to rename.	Search first, get an attorney's written opinion, then file. UK fees are £205 for one class and £60 for each extra one. Do not spend on the brand until this is clear.
MaternalLink ownership	No agreement exists with your collaborator (VERIFIED). He signs as "Founder & CEO, Maternal Link" and a prototype exists whose authorship is unknown.	Heads of terms within a week, a signed agreement within a month. It must cover the code, the name, the domain, the accounts, the decks, the relationships, and warranties on who wrote what. [SOLICITOR]
If no agreement is reached	You have a fallback, but it costs you.	By day 60, build version 1 cleanly from scratch, using none of his code, materials or the "Maternal Link" name.
Developers and contractors	Nothing signed.	Nobody writes a line of code before signing IP assignment, confidentiality and the open-source rules. No exceptions, ever.
Your own past work	Legally yours, not the company's, until you sign it over.	Sign the founder IP assignment on the day the company is registered.

Nigeria and other countries

- **Data:** Nigeria's Data Protection Act 2023 applies. Anything holding data on more than 200 people in six months must register with the NDPC, through a licensed compliance organisation. Health data needs explicit consent. Fees TO VALIDATE (we have not confirmed this).
- **Route in:** For a first pilot, contract through a local partner rather than registering a Nigerian company. Register only when a state contract is realistic.
- **Devices:** NAFDAC regulates medical devices. How it treats standalone software is TO VALIDATE.
- **Ethics:** Any pilot that evaluates participants needs approval from a recognised Nigerian ethics committee.
- **Bribery:** The UK Bribery Act 2010 follows you abroad. No facilitation payments, ever. Every payment goes through a contracted, invoiced route, and every government-facing document carries an anti-bribery clause.
- **Other markets:** South Africa (POPIA) and Kenya (Data Protection Act 2019) each need their own registration and local counsel. Do not open a third market before the first two work.

The risk list

Likelihood and impact are rated low, medium or high.

#	Risk	Likely	Bad	What you do about it
1	No ownership agreement, or a dispute, over MaternaLink	High	High	Heads of terms by day 7, signed by day 30, clean rebuild option at day 60

#	Risk	Likely	Bad	What you do about it
2	The name clashes and you have to rename	Medium	High	Clear the name before any brand spend; keep the rename plan ready
3	Claiming more than is true about the product, AI or partners	Medium	High	Every external piece passes a written claims check before it goes out
4	A feature quietly turns the product into a medical device	Medium	High	The line-crossing check on every feature; safety officer countersigns each release
5	Holding patient data with no lawful basis or DPIA	Medium	High	The prototype holds no real data until audited; DPIA before any deployment
6	A security breach on a weak prototype	Medium	High	Move to controlled hosting, multi-factor login everywhere, a penetration test, cyber insurance
7	Selling with no company and no insurance, so you are personally liable	High	Medium	Register by day 14; PI insurance before the first paid job
8	Nigeria: no NDPC registration, unlawful transfers, missing ethics approval	Medium	Medium	Local partner, register, host in-country, ethics approval before any pilot
9	Contractors classed as employees, or open-source licences you cannot use	Medium	Medium	Written status determinations from the accountant; licence scanning on every release
10	The rules change while you build (MHRA reform, data law, Nigerian guidance)	High	Medium	A 30-minute regulatory check every quarter; an adviser reads every major release

Who you must pay for proper advice

Do not do these yourself. Getting them wrong costs far more than the fee.

Who	What they are for	Roughly what it costs	When you need them
Solicitor (fixed-fee start-up firm)	The ownership agreement, your contract templates, shareholder documents, anything a partner or investor signs	£4k–£9k across the first 90 days	Instructed by Fri 18 Sept 2026
Trademark attorney	Clearing the name and filing the marks	£500–£1,500 for the opinion; £600–£1,200 to file	Before any brand spend
Accountant	Registration paperwork, tax, VAT, payroll, SEIS and EIS, contractor status	£80–£200 a month	From the day you register
Regulatory consultant	A written opinion on whether your software is a medical device, and what happens if it becomes one	£1,500–£4,000	Opinion commissioned by day 45
Clinical Safety Officer	A registered clinician who owns the hazard log and signs the safety case; the NHS will not buy without one	£500–£900 a day, one to two days a month	Identified by day 45, engaged by day 60
Insurance broker	Choosing the right cover and limits, not the cheapest quote	Paid through the premium	Before the first paid job
Nigerian counsel and a data compliance organisation	Nigerian registration, transfers and contracts	TO VALIDATE	Before any Nigerian pilot

Year-one legal and compliance budget: £9k–£18k (ESTIMATE). Treat it as the cost of being allowed to trade, not as an optional extra.

Words explained

Word	What it means
UK GDPR	The UK's data protection law. It says when you may hold information about people and how you must look after it.
Special-category data	The most protected kinds of information, including anything about health. Extra rules apply.
DPIA	A written check, done in advance, of what could go wrong with the data you plan to hold.
ICO	The UK regulator for data protection. You register with them and you report breaches to them.
MHRA	The UK regulator for medicines and medical devices.
Medical device	Any product, including software, that the maker intends to use to diagnose, monitor, predict or treat.
Intended use	The written statement of what your software is for. It is what decides whether you are a device maker.
DTAC	The NHS checklist a digital product must pass before a hospital can buy it.
DSPT	The annual NHS self-assessment on handling patient data safely.
Cyber Essentials	A government-backed certificate showing your security basics are in place.
Hazard log	The written list of ways the software could harm someone, and what you did about each.
Heads of terms	A short written summary of a deal, agreed before the full contract is drafted.
SEIS / EIS	Tax schemes that give people money back when they invest in a small British company.
TO VALIDATE	We have not confirmed this yet. Do not rely on it.
ESTIMATE	Our best guess, not a fact.